

## 網上威脅及保安

中五 | 必修單元：互聯網及其應用

|            |          |           |             |
|------------|----------|-----------|-------------|
| 姓名：_____   | 班別：_____ | 學號：_____  | 日期：_____    |
| 建議時限：40 分鐘 | 總分：50 分  | 程度：中五／DSE | 題型：選擇＋短答＋結構 |

## 學習目標 (對應課程指引)

描述常見網絡保安威脅所造成的潛在風險 (病毒、蠕蟲、木馬、間諜軟件、勒索軟件、未經授權存取、攔截、動態網頁入侵、DoS 等)。

提議有效措施以改善網絡保安 (防毒軟件、瀏覽器設定、認證與權限控制、防火牆、WPA、VPN 等)。

討論網上潛在私隱威脅，並建議保護私隱的方法。

## 甲部 多項選擇題 (每題 1 分，共 10 分)

請將正確答案填寫在括號內。

- 下列哪一項惡意軟件最可能透過電子郵件附件散播，並會自我複製至其他電腦？ ( )
  - 木馬程式 (Trojan)
  - 蠕蟲 (Worm)
  - 間諜軟件 (Spyware)
  - 廣告軟件 (Adware)
- 勒索軟件 (Ransomware) 的主要特徵是： ( )
  - 暗中記錄用戶的鍵盤輸入
  - 加密用戶檔案並要求支付贖金才解鎖
  - 偽裝成合法軟件，但不自我複製
  - 只顯示大量彈出式廣告
- 防火牆 (Firewall) 的主要功能是： ( )
  - 掃描並清除硬碟上的病毒
  - 根據規則監控並過濾進出網絡的流量
  - 為無線網絡提供加密密碼
  - 自動備份用戶的重要檔案
- 下列哪一項無線安全協議較 WEP 更安全，常被家用路由器採用？ ( )
  - HTTP
  - FTP
  - WPA／WPA2／WPA3
  - SMTP
- 虛擬私人網絡 (VPN) 最能幫助用戶： ( )
  - 加快下載速度
  - 在公共 Wi-Fi 上建立加密通道以保護傳輸數據
  - 取代防毒軟件
  - 自動修復被感染的系統檔案
- 仿冒詐騙 (Phishing) 通常透過以下哪種方式進行？ ( )

- A. 發送看似來自銀行的電郵，誘導用戶輸入帳號密碼
  - B. 向伺服器發送大量請求使其癱瘓
  - C. 在無線網絡上竊聽未加密的數據
  - D. 利用漏洞令程式緩衝區溢位
7. 拒絕服務攻擊 (DoS) 的目的是： ( )
- A. 竊取伺服器資料庫中的客戶資料
  - B. 使目標系統或網絡無法正常提供服務
  - C. 安裝後門以便日後遙控電腦
  - D. 修改網頁內容進行宣傳
8. 下列哪一項最能描述「認證」 (Authentication) ? ( )
- A. 決定用戶可以存取哪些資源
  - B. 核實用戶身份是否屬實
  - C. 加密傳輸中的數據
  - D. 記錄系統的所有操作日誌
9. 用戶在瀏覽器網址列見到「https://」及掛鎖圖示，通常表示： ( )
- A. 該網站一定沒有惡意軟件
  - B. 與伺服器之間的傳輸已加密 (如使用 SSL/TLS)
  - C. 該網站已通過政府認證
  - D. 用戶的防毒軟件正在運作
10. 「最小權限原則」 (Principle of Least Privilege) 是指： ( )
- A. 所有員工應使用同一個系統管理員帳號
  - B. 用戶只獲授予完成工作所需的最低權限
  - C. 關閉所有防火牆規則以方便存取
  - D. 禁止使用任何密碼

## 乙部 填充及配對 (共 10 分)

### B1 填充 (每空 1 分, 共 5 分)

請填寫適當的詞語。

11. \_\_\_\_\_ 會偽裝成有用程式誘騙用戶安裝，但本身一般不會自我複製。
12. \_\_\_\_\_ 會在用戶不知情下收集個人資料或上網習慣，並傳送給第三者。
13. \_\_\_\_\_ 是指未獲准許下進入電腦系統或網絡，例如黑客入侵。
14. 在公共場所使用未加密 Wi-Fi 時，攻擊者可能進行 \_\_\_\_\_，竊取傳輸中的敏感資料。
15. 定期更新 \_\_\_\_\_ 定義檔，有助偵測最新的惡意軟件。

### B2 配對 (每項 1 分, 共 5 分)

將左欄威脅／措施與右欄描述配對，把英文字母填在括號內。

| 左欄                      | 右欄                   |
|-------------------------|----------------------|
| 16. 病毒 ( )              | A. 限制不同用戶可讀寫的檔案或功能   |
| 17. 存取控制 ( )            | B. 需依附宿主檔案，感染後可破壞或複製 |
| 18. 雙重認證 (2FA) ( )      | C. 除密碼外再要求一次性驗證碼等    |
| 19. SQL 注入 (動態網頁入侵) ( ) | D. 透過惡意輸入操控資料庫查詢     |
| 20. 垃圾電郵 (Spam) ( )     | E. 大量未經索取的推廣或欺詐郵件    |

## 丙部 短答題 (共 15 分)

21. 比較「病毒」與「蠕蟲」在散播方式上的兩項主要分別。 [4 分]

22. 列出三項可改善個人電腦網絡保安的有效措施，並簡述每項如何減低風險。 [6 分]

23. 解釋認證 (Authentication) 與授權 (Authorization) 的分別，並各舉一例。 [5 分]

## 丁部 結構／情境題 (共 15 分)

細閱以下情境，然後回答問題。

### 情境

某中學的「電子學習平台」最近發生事故：多名師生收到聲稱來自「學校資訊科技組」的電郵，要求點擊連結並登入以「更新密碼」。部分同學在公共咖啡店的 Wi-Fi 下登入後，帳戶被盜用；同時平台曾短暫無法開啟。其後發現伺服器日誌出現大量異常請求。資訊科技組亦發現有老師的電腦出現檔案被加密、桌面留下勒索訊息的情況。

24. 指出情境中出現的三種不同網絡保安威脅，並分別說明其證據。 [6 分]

---

25. 就「公共 Wi-Fi 登入」一事，建議兩項保護措施，並解釋原因。 [4 分]

---

26. 學校應如何從技術及管理層面加強平台保安？提出三項建議。 [5 分]

---

## 溫習清單 (自我檢測)

完成工作紙後，請勾選你已掌握的概念：

- ☐ 能區分病毒、蠕蟲、木馬、間諜軟件、勒索軟件
- ☐ 明白未經授權存取、攔截、動態網頁入侵、DoS 的含義與影響
- ☐ 能提議防毒、防火牆、認證／權限、瀏覽器設定等措施
- ☐ 理解 WPA 與 VPN 如何保護無線／公共網絡傳輸
- ☐ 能討論釣魚、竊聽、垃圾電郵等私隱威脅及應對
- ☐ 分清認證與授權；認識 HTTPS／加密的基本作用
- ☐ 能就真實情境分析威脅並提出多層防禦建議

### 應試小貼士

結構題宜用「指出威脅 → 引用情境證據 → 建議措施並解釋」三段式作答。

比較題（如病毒 vs 蠕蟲）要寫「兩方面對比」，避免只描述其中一方。

措施題要寫「做什麼」＋「如何減低風險」，單講名稱通常只能得部分分。

注意課程用語：Authentication／Authorization、Firewall、VPN、WPA、DoS、Phishing。